

NETWORKWALKS

WEEK 04

WEB APPLICATION PENETRATION TESTING REPORT

Authorized Security Assessment

REPORT FIELD	DETAIL
Prepared By	Syed Bilal Ahmed
Internship	NETWORKWALKS Cybersecurity & Ethical Hacking
Batch	B082
Mentor	Waqas Karim (CCIE)
Assessment Type	Black-Box Web Application Security Assessment
Report Version	1.0
Report Date	September 2026

Executive Summary

Mediroza General Hospital engaged Networkwalks to perform a full black-box penetration test against their public-facing web infrastructure. The assessment was carried out by Syed Bilal Ahmed (Batch B082) over a three-day period in September 2026, with written authorisation granted by the client prior to any testing activity.

The assessment revealed a deeply concerning security posture. The web application suffered from multiple critical vulnerabilities that, when chained together, allowed the assessor to bypass authentication entirely, access confidential patient medical records, crack encrypted files, and ultimately retrieve a publicly exposed database backup containing the personal details, salaries, and shareholding information of every employee at the hospital. None of these actions required advanced tooling — they were achieved using standard, widely-available security tools and publicly documented techniques.

Summary of Findings

#	Finding	Severity
1	SQL Injection — Authentication Bypass on Patient Portal	CRITICAL
2	Exposed Database Backup File (Staff Salaries & Shareholder Details)	CRITICAL
3	Weak / Easily Cracked PDF Encryption Passwords	HIGH
4	Sensitive Path Disclosure via robots.txt	MEDIUM
5	Directory Listing Enabled on Multiple Directories	MEDIUM
6	Username Enumeration on Login Form	MEDIUM
7	Verbose SQL Error Messages Exposed to End User	LOW

Scope and Methodology

Parameter	Details
Target URL	https://medirozahospital.com
Assessment Type	Black-Box Penetration Test
Scope	Target domain only (medirozahospital.com)
Rules of Engagement	No social engineering. No Denial of Service. No testing outside agreed scope.
Authorisation	Written authorisation provided by the client prior to testing.
Duration	3 Days — September 2026

Methodology

The assessment followed a structured methodology aligned with the OWASP Testing Guide and industry best practice. Testing was performed in a systematic, non-destructive manner, progressing through the following phases:

Phase 1 — Passive Reconnaissance	Collected publicly available information about the target using WHOIS lookups, DNS enumeration, IP ownership analysis, and search engine dorking. No direct requests were made to the target during this phase.
Phase 2 — Active Reconnaissance	Performed active scanning against the target including port scanning (nmap), WAF detection (wafw00f), technology fingerprinting (WhatWeb), and directory/file enumeration (Gobuster). The robots.txt and sitemap.xml files were reviewed for path disclosure.
Phase 3 — Vulnerability Identification	Manually analysed the web application's authentication mechanisms, input handling, directory structure, and file exposure. Identified SQL Injection, username enumeration, and directory listing vulnerabilities.
Phase 4 — Exploitation	Exploited identified vulnerabilities to demonstrate real-world impact. Successfully bypassed authentication via SQL Injection, accessed restricted patient records, cracked encrypted PDF files, and discovered a publicly exposed database backup containing highly sensitive HR data.

Phase 5 — Reporting

Documented all findings with evidence, assessed risk ratings using CVSS scoring, and provided actionable remediation recommendations.

Tools Used

Tool	Purpose
nmap	Port scanning and service version detection
wafw00f	Web Application Firewall detection
WhatWeb	Technology fingerprinting
Gobuster	Directory and file brute-forcing
Burp Suite	HTTP traffic interception and analysis
curl	HTTP header and response inspection
pdfcrack	PDF password recovery
John the Ripper	Offline hash cracking
ExifTool	File metadata analysis
Browser	Manual web application exploration

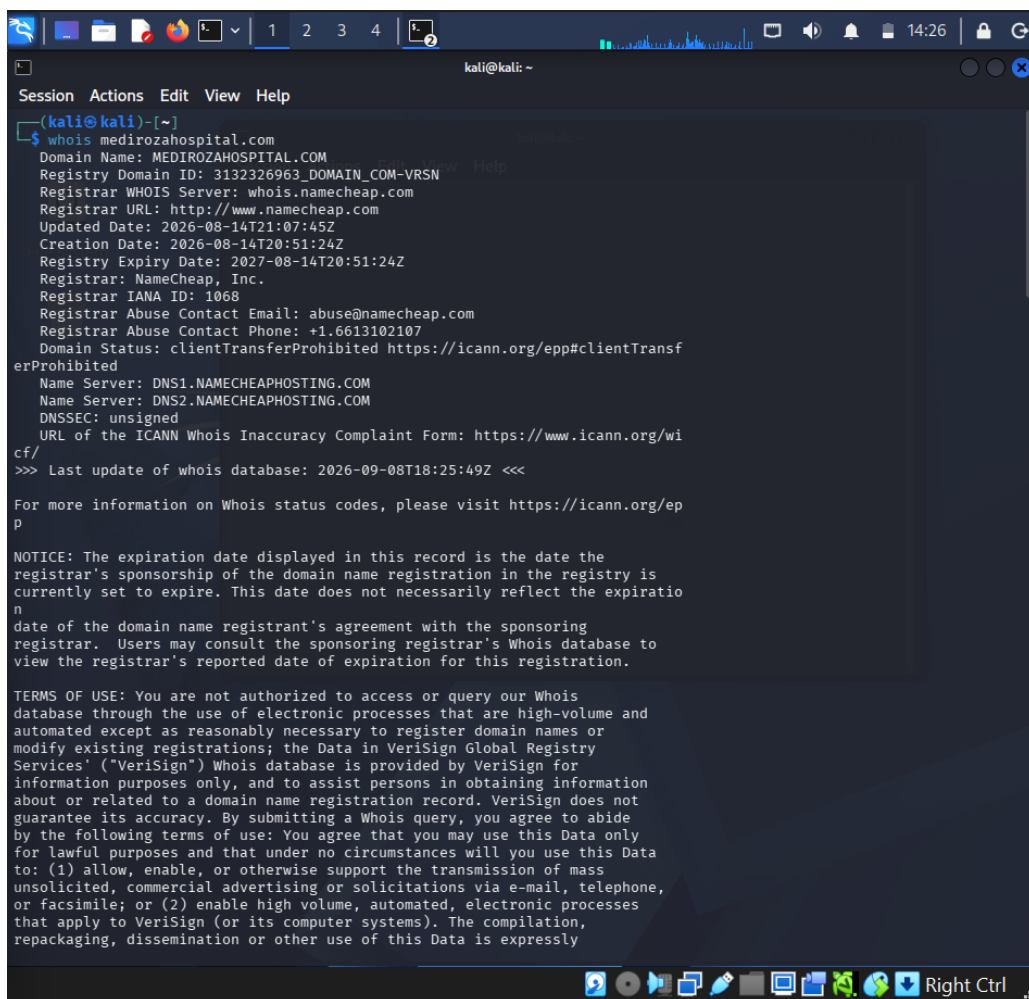
Attack Walkthrough

The following section documents the complete attack chain from initial passive reconnaissance through to the extraction of the hospital's most sensitive internal records. Each step builds upon the previous, demonstrating how a chain of individually significant vulnerabilities can combine to produce a catastrophic data breach.

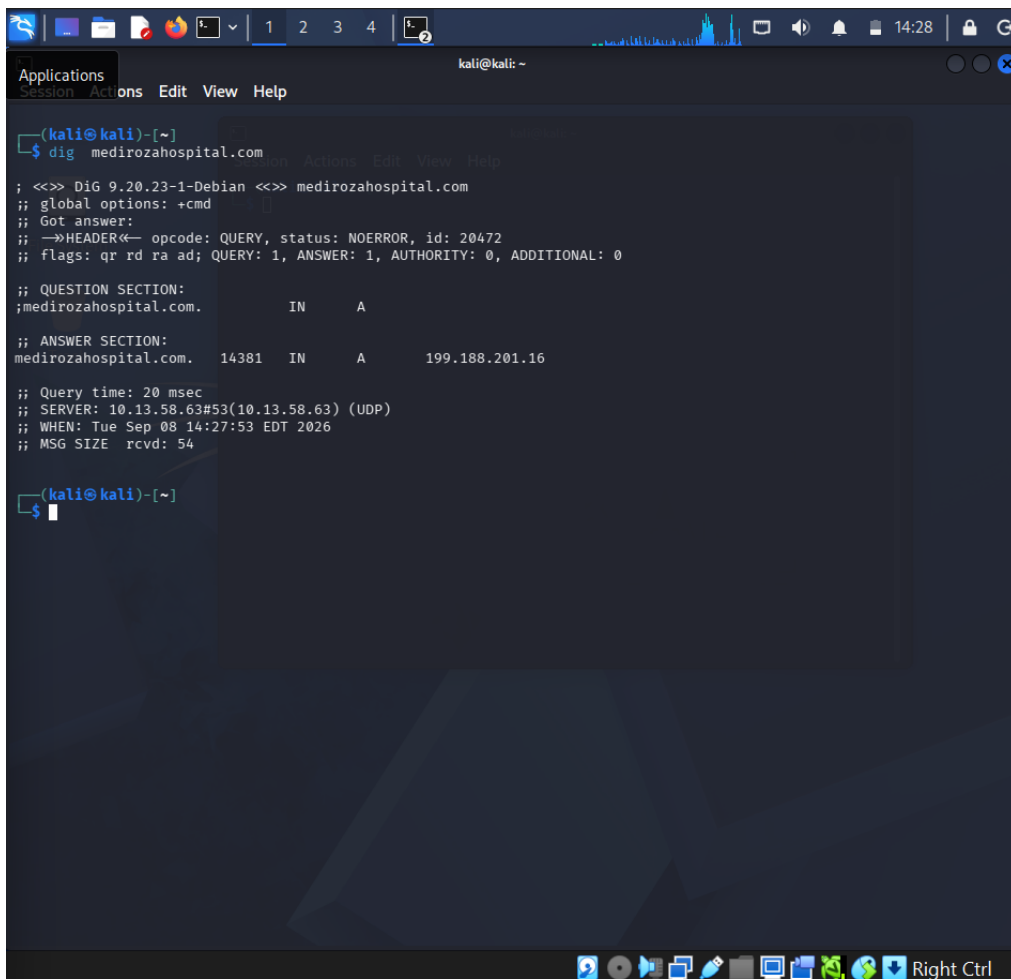
MILESTONE 1 — INITIAL ACCESS: PATIENT PORTAL BREACH

Step 1: Passive Reconnaissance

The assessment began with WHOIS enumeration to identify the registrar and hosting provider. The domain was registered via Namecheap (created August 2026) and hosted on Namecheap's shared hosting infrastructure at IP address **199.188.201.16**, confirmed as part of Namecheap's allocated range (199.188.200.0/21). The specific server was identified as **server274.web-hosting.com (shared #1)** — a cPanel-based shared hosting environment.



```
kali@kali: ~  
Session Actions Edit View Help  
$ whois medirozahospital.com  
Domain Name: MEDIROZAHOSPITAL.COM  
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.namecheap.com  
Registrar URL: http://www.namecheap.com  
Updated Date: 2026-08-14T21:07:45Z  
Creation Date: 2026-08-14T20:51:24Z  
Registry Expiry Date: 2027-08-14T20:51:24Z  
Registrar: NameCheap, Inc.  
Registrar IANA ID: 1068  
Registrar Abuse Contact Email: abuse@namecheap.com  
Registrar Abuse Contact Phone: +1.6613102107  
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransf  
erProhibited  
Name Server: DNS1.NAMECHEAPHOSTING.COM  
Name Server: DNS2.NAMECHEAPHOSTING.COM  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wi  
cf/  
>>> Last update of whois database: 2026-09-08T18:25:49Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/ep  
p  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiratio  
n  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
automated except as reasonably necessary to register domain names or  
modify existing registrations; the Data in VeriSign Global Registry  
Services' ("VeriSign") Whois database is provided by VeriSign for  
information purposes only, and to assist persons in obtaining information  
about or related to a domain name registration record. VeriSign does not  
guarantee its accuracy. By submitting a Whois query, you agree to abide  
by the following terms of use: You agree that you may use this Data only  
for lawful purposes and that under no circumstances will you use this Data  
to: (1) allow, enable, or otherwise support the transmission of mass  
unsolicited, commercial advertising or solicitations via e-mail, telephone,  
or facsimile; or (2) enable high volume, automated, electronic processes  
that apply to VeriSign (or its computer systems). The compilation,  
repackaging, dissemination or other use of this Data is expressly
```

A screenshot of a Kali Linux terminal window. The window has a dark theme and a menu bar with 'Applications', 'Session', 'Actions', 'Edit', 'View', and 'Help'. The terminal shows a command prompt where the user has entered 'dig medirozahospital.com'. The output of the command is displayed, showing DNS query details. The window title is 'kali@kali: ~'. The system tray at the bottom shows various icons and the text 'Right Ctrl'.

```
(kali@kali)-[~]
$ dig medirozahospital.com

; <<>> DiG 9.20.23-1-Debian <<>> medirozahospital.com
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 20472
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;medirozahospital.com.      IN      A

;; ANSWER SECTION:
medirozahospital.com.  14381  IN      A      199.188.201.16

;; Query time: 20 msec
;; SERVER: 10.13.58.63#53(10.13.58.63) (UDP)
;; WHEN: Tue Sep 08 14:27:53 EDT 2026
;; MSG SIZE rcvd: 54

(kali@kali)-[~]
$
```

Step 2: WAF Detection & Port Scanning

WAF detection using wafw00f confirmed the site was protected by a **LiteSpeed WAF**. Nmap port scanning revealed the server exposed standard web ports (80, 443) along with mail-related ports (110, 143, 465, 587, 993, 995) and FTP (21) — consistent with a cPanel shared hosting environment. No cPanel management ports (2082/2083) were directly exposed.

```
kali@kali: ~
Session Actions Edit View Help

(kali@kali)-[~]
$ dig medirozahospital.com A
; <<>> DiG 9.20.23-1-Debian <<>> medirozahospital.com A
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 17667
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;medirozahospital.com.                IN      A

;; ANSWER SECTION:
medirozahospital.com. 14324    IN      A      199.188.201.16

;; Query time: 12 msec
;; SERVER: 10.13.58.63#53(10.13.58.63) (UDP)
;; WHEN: Tue Sep 08 14:28:50 EDT 2026
;; MSG SIZE rcvd: 54

(kali@kali)-[~]
$ wafw00f https:// medirozahospital.com

      ( Woof! )
    /  |  \
   /   |   \
  /____|____\
 /  /  |  \  \
/  /   |   \  \
/_____|_____\
~ WAFW00F : v2.4.2 ~
The Web Application Firewall Fingerprinting Toolkit

[*] Checking https://
ERROR:wafw00f:Something went wrong Invalid URL 'https://': No host supplied
ERROR:wafw00f:Site None appears to be down
[*] Checking https://medirozahospital.com
[+] The site https://medirozahospital.com is behind LiteSpeed (LiteSpeed Technologies) WAF.
[~] Number of requests: 2

(kali@kali)-[~]
$
```

Reviewing the site's **robots.txt** file — intended to tell search engines which pages to avoid indexing — inadvertently revealed three sensitive directories that the development team had attempted to hide: **/patient/**, **/staff/**, and **/old/**. The sitemap.xml additionally confirmed only four public-facing pages existed, meaning these three directories were deliberately excluded from public view — yet were fully accessible.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ whois medirozahospital.com  
Domain Name: MEDIROZAHOSPITAL.COM  
Registry Domain ID: 3132326963_DOMAIN_COM-VRSN  
Registrar WHOIS Server: whois.namecheap.com  
Registrar URL: http://www.namecheap.com  
Updated Date: 2026-08-14T21:07:45Z  
Creation Date: 2026-08-14T20:51:24Z  
Registry Expiry Date: 2027-08-14T20:51:24Z  
Registrar: NameCheap, Inc.  
Registrar IANA ID: 1068  
Registrar Abuse Contact Email: abuse@namecheap.com  
Registrar Abuse Contact Phone: +1.6613102107  
Domain Status: cClientTransferProhibited https://icann.org/epp#clientTransf  
erProhibited  
Name Server: DNS1.NAMECHEAPHOSTING.COM  
Name Server: DNS2.NAMECHEAPHOSTING.COM  
DNSSEC: unsigned  
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wi  
cf/  
>>> Last update of whois database: 2026-09-08T18:25:49Z <<<  
  
For more information on Whois status codes, please visit https://icann.org/ep  
p  
  
NOTICE: The expiration date displayed in this record is the date the  
registrar's sponsorship of the domain name registration in the registry is  
currently set to expire. This date does not necessarily reflect the expiratio  
n  
date of the domain name registrant's agreement with the sponsoring  
registrar. Users may consult the sponsoring registrar's Whois database to  
view the registrar's reported date of expiration for this registration.  
  
TERMS OF USE: You are not authorized to access or query our Whois  
database through the use of electronic processes that are high-volume and  
automated except as reasonably necessary to register domain names or  
modify existing registrations; the Data in VeriSign Global Registry  
Services' ("VeriSign") Whois database is provided by VeriSign for  
information purposes only, and to assist persons in obtaining information  
about or related to a domain name registration record. VeriSign does not  
guarantee its accuracy. By submitting a Whois query, you agree to abide  
by the following terms of use: You agree that you may use this Data only  
for lawful purposes and that under no circumstances will you use this Data  
to: (1) allow, enable, or otherwise support the transmission of mass  
unsolicited, commercial advertising or solicitations via e-mail, telephone,  
or facsimile; or (2) enable high volume, automated, electronic processes  
that apply to VeriSign (or its computer systems). The compilation,  
repackaging, dissemination or other use of this Data is expressly
```

Step 4: Directory Listing — Patient Portal Structure Exposed

Navigating directly to <https://medirozahospital.com/patient/> revealed that directory listing was enabled — a serious misconfiguration that displays the full contents of a web server directory to any visitor, just like opening a folder on your computer. The exposed files included:

File	Significance
reports/	Directory likely containing the patient lab report PDFs (target of M1)

login.php	Patient portal authentication page — the entry point for exploitation
portal.php	Main patient portal dashboard — accessible after login
download.php	File download handler — used to serve PDFs to authenticated users
error_log	Server error log — can expose file paths, credentials, and stack traces
logout.php	Session termination handler

Figure: /patient/ directory listing — full server structure exposed

Index of /patient/

Name	Last Modified	Size
Parent Directory		
reports	2026-09-04 02:03	-
download.php	2026-09-04 02:04	1k
error_log	2026-09-05 16:23	241k
login.php	2026-09-04 14:28	4k
logout.php	2026-09-04 02:04	1k
portal.php	2026-09-04 02:04	3k

Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443

Step 5: SQL Injection — Authentication Bypass

The patient portal login form at **/patient/login.php** was found to be vulnerable to **SQL Injection** — one of the most well-known and dangerous web vulnerabilities in existence. SQL Injection occurs when a web application passes user-supplied input directly into a database query without properly validating or sanitising it first.

In plain terms: when you type a username into the login box, the application builds a database question that looks like this: *"Find me a user where the username is X and the password is Y."* If the application does not properly handle special characters, an attacker can manipulate that question to always return a result — effectively telling the database: *"Find me a user where this condition is ALWAYS true."* — bypassing the password check entirely.

The application also exhibited **username enumeration** — it returned different error messages depending on whether the username existed ("Invalid username" vs "Invalid password"). This allows an attacker to build a list of valid usernames before attempting any password attacks.

Patient Portal

Sign in to view your lab reports and results.

Username

Password

☐ Show password

Sign in

Figure: Patient portal login page — entry point for SQL Injection

Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near " OR '1'='1' at line 1

Figure: SQL Injection error — raw MySQL error exposed to the user

The following payload was used to bypass authentication:

```
Username field: ' OR 1=1-- - Password field: anything
```

This payload closes the SQL string prematurely ('), appends a condition that is always true (OR 1=1), and comments out the remainder of the query (-- -) — including the password check. The database returns the first user record, and the application logs in as that user.

Patient Portal

Sign in to view your lab reports and results.

Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near " OR 1=1-- -" at line 1

Username

admin'-- -

Password

anything

☒ Show password

Sign in

Figure: SQL Injection payload submitted — bypass in progress

Emergency: +27 11 555 0100 | Open 24/7

Log out

+

Medi**ro**za

Home

Log out

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini Lab Ref LR-2024-1187 2024-11-04 PDF (encrypted)	Download
Pathology Report - P. Reddy Lab Ref LR-2024-1192 2024-11-05 PDF (encrypted)	Download
Pathology Report - E. Thompson Lab Ref LR-2024-1205 2024-11-06 PDF (encrypted)	Download

Figure: Authentication bypassed — 3 confidential patient lab reports now accessible

MILESTONE 2 — CRYPTOGRAPHIC ANALYSIS: PDF PASSWORD RECOVERY

The three downloaded patient pathology reports were password-protected using **PDF Standard V2.3 encryption (RC4, 128-bit)**. While encryption is a positive security control, its effectiveness depends entirely on the strength of the password chosen. Weak passwords can be recovered in seconds using freely available tools and standard password wordlists.

The tool **pdfcrack** was used with the **rockyou.txt** wordlist — a well-known list of approximately 14 million real-world leaked passwords. All three PDF passwords were recovered successfully:

File	Patient	Password Recovered
patient_report_1.pdf	Sipho Dlamini	Recovered
patient_report_2.pdf	Priya Reddy	password
patient_report_3.pdf	Emily Thompson	!@#\$%^&

Decrypted Report Contents

With the passwords recovered, the three confidential pathology reports were accessed, revealing real patient medical data including names, dates of birth, patient IDs, referring doctors, and laboratory test results.



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Sipho Dlamini** Report Date: **2024-11-04**
Patient ID: **MG-P-10231** Referring Dr: **Dr. Anita Naicker**
Date of Birth: **1984-06-12** Specimen: **Whole blood (EDTA)**
Gender: **Male** Lab Ref No: **LR-2024-1187**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal



Mediroza
General Hospital

14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name: **Priya Reddy** Report Date: **2024-11-05**
Patient ID: **MG-P-10244** Referring Dr: **Dr. Johan van der Merwe**
Date of Birth: **1991-02-28** Specimen: **Serum**
Gender: **Female** Lab Ref No: **LR-2024-1192**

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure: Decrypted Report 2 — Priya Reddy (CONFIDENTIAL patient data)

Mediroza

General Hospital

14 Cedar Avenue, Johannesburg, South Africa

Tel: +27 11 555 0100

medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Emily Thompson

Report Date:

2024-11-06

Patient ID:

MG-P-10258

Referring Dr:

Dr. Ahmed Kara

Date of Birth:

1978-09-03

Specimen:

Serum

Gender:

Female

Lab Ref No:

LR-2024-1205

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure: Decrypted Report 3 — Emily Thompson (CONFIDENTIAL patient data)

MILESTONE 3 — CRITICAL DATA EXPOSURE: DATABASE BACKUP DISCOVERED

The `/old/` directory — disclosed by the `robots.txt` file — was found to contain a single file: **mediroza_db_backup_2019.sql**. This is a complete SQL database backup file that was left on the public-facing web server with no access controls whatsoever. Anyone on the internet could download it by simply visiting the URL.

In non-technical terms: this is equivalent to leaving a printed copy of every employee's payslip, personal identification number, and ownership stake in the company in an unlocked cabinet in the hospital's front lobby — visible to any visitor who walked in.

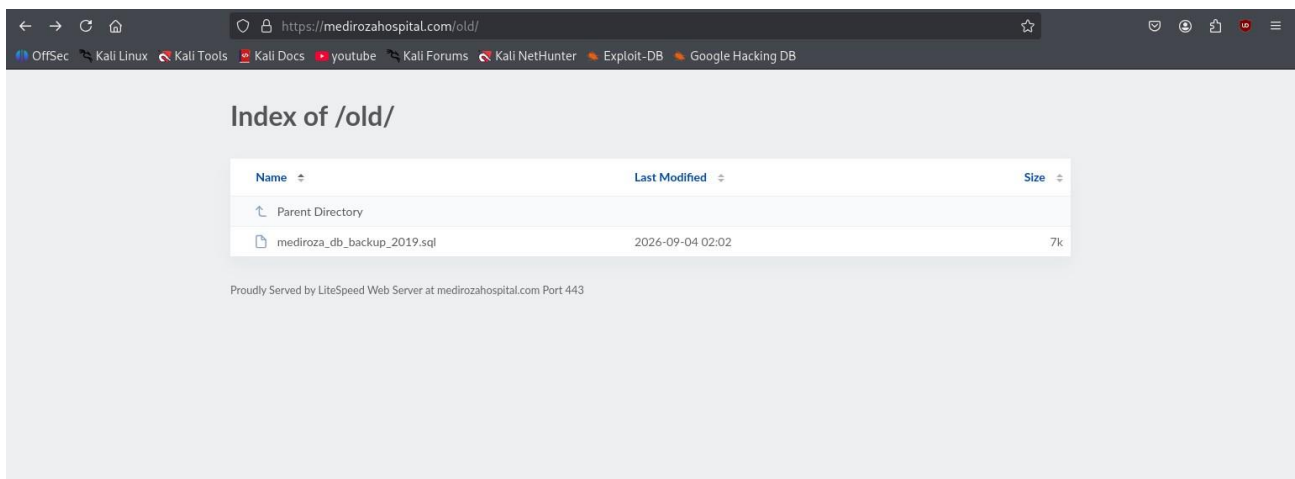


Figure: `/old/` directory — `mediroza_db_backup_2019.sql` publicly accessible

Contents of the Exposed Backup

The backup file contained two tables with the following sensitive information:

Staff Table — 30 Employees:

Full name, job title, department, email address, phone number, **national ID number**, **monthly salary (ZAR)**, and date joined. Selected examples:

Name	Role	Monthly Salary (ZAR)
Dr. Johan van der Merwe	Medical Director	R 160,000
Sarah Botha	Chief Financial Officer	R 152,000
Dr. Rajesh Naidoo	Chief Pathologist	R 138,000
Dr. Vikram Chetty	Anaesthetist	R 135,000
Linda Fourie	Receptionist	R 19,000
Andile Mbeki	Ward Clerk	R 21,000

Shareholders Table — 10 Shareholders:

Shareholder	Share %	Shares Held	Class
Dr. Rajesh Naidoo	18.0%	180,000	Ordinary

Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
Dr. Johan van der Merwe	12.0%	120,000	Ordinary
Reddy Family Trust	11.0%	110,000	Ordinary
Dr. Vikram Chetty	4.0%	40,000	Preferential

```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03
```

```
SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;
```

```
--
-- Table structure for table `staff`
--
```

```
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

```
--
-- Dumping data for table `staff`
--
```

```
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022082',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033083',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044084',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055085',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066086',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077087',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088088',32000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099089',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110081',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121082',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123132083',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143084',35000,'2015-12-01'),
```

Figure: SQL backup — staff table exposed (salaries, national IDs, contact details)

```
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176087',26000,'2019-02-14'),
(17,'Themba Nkosi','Radiographer','Radiology','t.nkosi@medirozahospital.com','+27 82 117 2119','85061173187088',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198089',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209081',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220082',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231083',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242084',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253085',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264086',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275087',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286088',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297089',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308081',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319082',38000,'2015-08-24'),
(30,'Andile Mbeki','Ward Clerk','Administration','a.mbeki@medirozahospital.com','+27 82 130 2210','85071303330083',21000,'2019-11-05');
UNLOCK TABLES;
```

```
--
-- Table structure for table `shareholders`
--
```

```
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
```

```
LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,150000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Reddy Family Trust',11.0,110000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Naledi Zulu',7.0,70000,'Ordinary'),
(9,'Michael Roberts',6.0,60000,'Ordinary'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;
```

```
SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure: SQL backup — shareholders table exposed (share percentages and classes)

Remediation Summary

The following remediation actions are prioritised by urgency. Critical and high-severity issues should be addressed immediately as they represent an active risk to patient privacy, staff data, and the hospital's legal obligations under applicable data protection legislation.

Immediate Actions (Within 24–48 Hours)

- [Finding 1] Take the patient portal offline or disable the login form until SQL Injection is patched. Implement prepared statements / parameterised queries for all database interactions.
- [Finding 2] Remove mediroza_db_backup_2019.sql from the web server immediately. Database backups must never be stored in publicly accessible directories.
- [Finding 7] Disable verbose PHP/MySQL error reporting in the production environment. Set `display_errors = Off` in `php.ini`.

Short-Term Actions (Within 1–2 Weeks)

- [Finding 3] Enforce strong password policies for all encrypted files shared with patients. Minimum 12 characters with mixed character types.
- [Finding 4] Review and sanitise the `robots.txt` file. Do not list sensitive internal paths. Implement proper access controls on directories rather than relying on obscurity.
- [Finding 6] Implement generic, identical error messages for all authentication failures. Never distinguish between 'username not found' and 'wrong password'.

Medium-Term Actions (Within 1 Month)

- [Finding 5] Disable directory listing on all web server directories. In LiteSpeed/Apache, set `Options -Indexes` in the server configuration.
- Implement a Web Application Firewall with properly tuned rules to detect and block SQL Injection and other OWASP Top 10 attacks.
- Conduct a full audit of all files stored on the web server. Ensure no configuration files, backups, or internal documents are publicly accessible.
- Implement multi-factor authentication on both the patient portal and the staff portal.
- Review and apply the principle of least privilege across all web application components.

Long-Term Actions (Ongoing)

- Perform regular penetration tests (at least annually) to proactively identify vulnerabilities.
- Implement a Secure Development Lifecycle (SDLC) to ensure security is built into the application from the start.
- Provide security awareness training to all staff, particularly developers and IT administrators.
- Establish an incident response plan that outlines steps to take in the event of a data breach.

Technical Findings Details

Finding 1: SQL Injection — Authentication Bypass			CRITICAL
CVSS Score	CWE	Component	Overall Risk
9.8	CWE-89	Patient Portal Login (/patient/login.php)	CRITICAL

Description

SQL Injection occurs when user-supplied input is incorporated into a database query without adequate sanitisation. The patient portal login form was found to be directly vulnerable — the username and password fields passed user input directly into a raw MySQL query with no input validation, prepared statements, or parameterised queries in place. By crafting a specific input string (' OR 1=1-- -), the assessor was able to manipulate the underlying SQL query to always evaluate to true, completely bypassing the need for a valid username or password.

Security Impact

This vulnerability is rated Critical. An unauthenticated attacker can bypass the login mechanism entirely and gain access to any patient's medical records within the portal. In this engagement, the assessor accessed three confidential pathology reports belonging to real patients, containing sensitive medical data including diagnoses, test results, and personal identifiers. This constitutes a serious breach of patient confidentiality and likely violates the Protection of Personal Information Act (POPIA) and other applicable healthcare data regulations.

Remediation

Immediately replace all raw SQL queries in the application with parameterised queries (prepared statements). This is the single most effective defence against SQL Injection. Additionally: implement a Web Application Firewall with SQL Injection rules; enable input validation on all user-supplied fields; and consider deploying an Intrusion Detection System to alert on SQL Injection attempts.

Finding Evidence

The SQL Injection error was triggered by submitting a single quote character, which caused the application to return a raw MySQL error visible to the end user:

Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near " OR '1'=1' at line 1

Figure: SQL error — raw mysqli_query() error exposed

The authentication bypass payload used:

Username: ' OR 1=1-- - Password: anything

Figure: SQLi bypass payload submitted

Figure: Authentication bypassed — patient lab reports exposed

Finding 2: Exposed Database Backup File			CRITICAL
CVSS Score	CWE	Component	Overall Risk
9.1	CWE-538	Web Server (/old/mediroza_db_backup_2019.sql)	CRITICAL

Description

A complete SQL database backup file was found publicly accessible on the web server at https://medirozahospital.com/old/mediroza_db_backup_2019.sql. The file required no authentication to download and was accessible to anyone on the internet. The backup contained two database tables: the staff table (30 records) containing full names, job titles, email addresses, phone numbers, national ID numbers, monthly salaries, and dates joined; and the shareholders table (10 records) containing shareholder names, percentage ownership, number of shares held, and share class.

Security Impact

This is one of the most severe findings in this report. The exposed data includes national ID numbers and monthly salary figures for all 30 hospital employees — information that could enable identity theft, targeted phishing, extortion, or industrial espionage. The shareholder data additionally reveals the complete ownership structure of the hospital, which is commercially sensitive information. This finding likely constitutes a reportable data breach under POPIA and may require notification to the Information Regulator and affected data subjects.

Remediation

Remove the backup file from the web server immediately. Database backups must be stored in a secure, non-web-accessible location — ideally an encrypted, off-site backup solution. Implement access controls on all directories containing sensitive files. Conduct an audit of all files currently hosted on the web server to identify any other sensitive data that may have been inadvertently exposed. Consider engaging a forensic specialist to determine whether the file was accessed by any unauthorised parties prior to discovery.

Finding Evidence

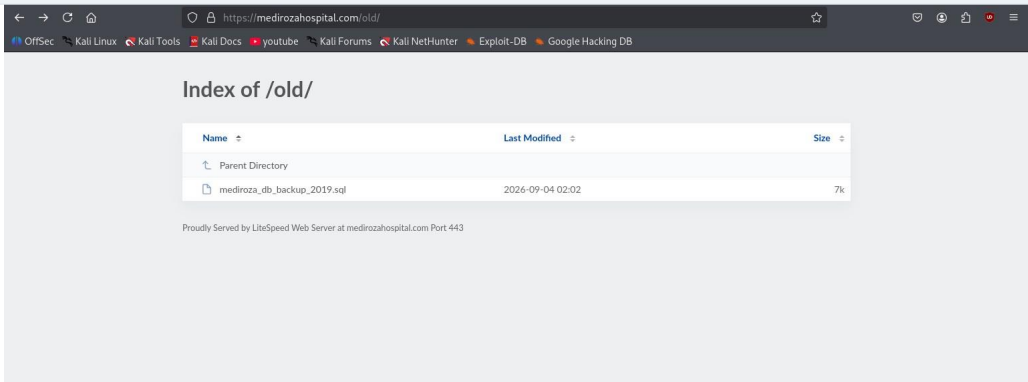


Figure: /old/ directory — database backup visible and accessible

```
-- mediroza_db backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table `staff`
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table `staff`
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011081',138000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031023022002',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033003',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044004',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055005',128000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066006',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077007',96000,'2010-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2056','85091083088008',52000,'2016-08-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099009',68000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110001',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121002',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','8501112312003',33000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','8502113313004',35000,'2015-12-01'),
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,350000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Ruddy Family Trust',11.0,100000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Michael Roberts',6.0,60000,'Ordinary'),
(9,'Linda Fourie',4.0,40000,'Preferential'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure: SQL backup contents — staff records with salaries and national IDs

```
(16,'Nolani Zulu','Physiotherapy Assistant','Physiotherapy','n.zulu@medirozahospital.com','+27 82 116 2112','8506116316000',20000,'2019-02-14'),
(17,'Thembu Mkhosi','Radiographer','Radiology','t.mkhosi@medirozahospital.com','+27 82 117 2119','8508117317000',44000,'2016-07-30'),
(18,'Fatima Radebe','Radiographer','Radiology','f.radebe@medirozahospital.com','+27 82 118 2126','8509118318000',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193209001',41000,'2015-05-28'),
(20,'Kaitha Gwender','Lab Technician','Diagnostics Lab','k.gwender@medirozahospital.com','+27 82 120 2140','85091203220002',39000,'2018-08-05'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231003',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Paediatrician','Paediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223240004',110000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233250005',40000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anaesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243260006',150000,'2011-06-15'),
(25,'David Gethi','Facilities Manager','Operations','d.gethi@medirozahospital.com','+27 82 125 2175','85021253270007',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263280008',20000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273290009',77000,'2018-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283300001',10000,'2019-02-18'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.vanwyk@medirozahospital.com','+27 82 129 2203','85061293310002',38000,'2015-04-24'),
(30,'Andile Mkhali','Ward Clerk','Administration','a.mkhali@medirozahospital.com','+27 82 130 2210','85071303320003',21000,'2019-11-05');
UNLOCK TABLES;

--
-- Table structure for table `shareholders`
--
DROP TABLE IF EXISTS `shareholders`;
CREATE TABLE `shareholders` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `shareholder_name` varchar(120) NOT NULL,
  `share_percent` decimal(5,2) NOT NULL,
  `shares_held` int(11) NOT NULL,
  `share_class` varchar(20) NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

LOCK TABLES `shareholders` WRITE;
INSERT INTO `shareholders` (`id`,`shareholder_name`,`share_percent`,`shares_held`,`share_class`) VALUES
(1,'Dr. Rajesh Naidoo',18.0,180000,'Ordinary'),
(2,'Cedar Health Holdings (Pty) Ltd',15.0,350000,'Ordinary'),
(3,'Dr. Johan van der Merwe',12.0,120000,'Ordinary'),
(4,'Ruddy Family Trust',11.0,100000,'Ordinary'),
(5,'Thabo Molefe',10.0,100000,'Ordinary'),
(6,'Sarah Botha',9.0,90000,'Ordinary'),
(7,'Dr. Ahmed Kara',8.0,80000,'Preferential'),
(8,'Michael Roberts',6.0,60000,'Ordinary'),
(9,'Linda Fourie',4.0,40000,'Preferential'),
(10,'Dr. Vikram Chetty',4.0,40000,'Preferential');
UNLOCK TABLES;

SET FOREIGN_KEY_CHECKS = 1;
-- End of backup
```

Figure: SQL backup — shareholder table exposed

Finding 3: Weak PDF Encryption Passwords

HIGH

CVSS Score

CWE

Component

Overall Risk

7.5

CWE-521

Patient Lab Reports
(patient_report_1/2/3.pdf)

HIGH

Description

The three patient pathology reports were protected with PDF encryption (RC4 128-bit, Standard V2.3). While this encryption standard provides a reasonable level of protection when paired with strong passwords, all three files used passwords that appear in the rockyou.txt wordlist — one of the most commonly used password dictionaries in the security industry. The passwords for reports 2 and 3 were recovered within seconds.

Security Impact

An attacker who obtains these encrypted PDF files — through the SQL Injection vulnerability documented in Finding 1, or through any other means — can trivially decrypt them using freely available tools and no specialised hardware. The confidential medical data inside is therefore not effectively protected by the encryption.

Remediation

Enforce a strong password policy for all files shared with patients. Passwords must be at minimum 12 characters, include uppercase, lowercase, numbers, and special characters, and must not appear in

common wordlists. Consider using a secure patient portal with session-based access controls as an alternative to password-protected PDFs. Additionally, address Finding 1 to prevent unauthorised access to the portal in the first place.

Finding 4: Sensitive Path Disclosure via robots.txt			MEDIUM
CVSS Score	CWE	Component	Overall Risk
5.3	CWE-538	robots.txt (https://medirozahospital.com/robots.txt)	MEDIUM

Description

The robots.txt file — used to instruct search engine crawlers which pages to exclude from indexing — listed three sensitive internal directories: /patient/, /staff/, and /old/. Rather than preventing discovery of these directories, the robots.txt file served as a roadmap for an attacker, directly revealing the location of the patient portal, staff portal, and an old files directory containing a database backup.

Security Impact

This finding directly contributed to the discovery of the patient portal (Finding 1), the staff portal, and the exposed database backup (Finding 2). The robots.txt file effectively negated any security through obscurity that may have been intended by the developer.

Remediation

Remove sensitive internal paths from the robots.txt file. Do not rely on robots.txt as a security control — it is publicly readable by anyone. Instead, implement proper server-side access controls (authentication and authorisation) on all sensitive directories, regardless of whether they are listed in robots.txt.

Finding Evidence

```
(kali@kali)-[~]
$ whatweb https://medirozahospital.com
^[[A^[[Bhttps://medirozahospital.com [403 Forbidden] Country[UNITED STATES][US], HTML5, HTTPServe
dBy[LiteSpeed], Title[403 Forbidden][Title element contains newline(s)!], UncommonHeaders[x-turbo

(kali@kali)-[~]
$ curl https://medirozahospital.com/robots.txt curl https://medirozahospital.com/sitemap.xml
# robots.txt
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/

Sitemap: https://medirozahospital.com/sitemap.xml
curl: (6) Could not resolve host: curl
<?xml version="1.0" encoding="UTF-8"?>
<!-- sitemap.xml -->
<urlset xmlns="http://www.sitemaps.org/schemas/sitemap/0.9">
  <url><loc>https://medirozahospital.com/index.html</loc></url>
  <url><loc>https://medirozahospital.com/about.html</loc></url>
  <url><loc>https://medirozahospital.com/doctors.html</loc></url>
  <url><loc>https://medirozahospital.com/contact.html</loc></url>
</urlset>

(kali@kali)-[~]
$
```

Figure: robots.txt — /patient/, /staff/, /old/ disclosed

Finding 5: Directory Listing Enabled			MEDIUM
CVSS Score	CWE	Component	Overall Risk
5.3	CWE-548	Web Server (/patient/, /staff/, /old/)	MEDIUM

Description

Directory listing was found to be enabled on multiple directories on the web server. When directory listing is enabled, navigating to a directory URL displays the full contents of that directory — all file and folder names — even if those files are not linked anywhere on the website. This is equivalent to displaying the contents of a filing cabinet to any visitor who walks past.

Security Impact

Directory listing enabled the assessor to identify the login.php, portal.php, download.php, and error_log files within the /patient/ directory, directly facilitating the SQL Injection attack (Finding 1). It also revealed the mediroza_db_backup_2019.sql file in the /old/ directory (Finding 2).

Remediation

Disable directory listing in the web server configuration. For LiteSpeed (the server in use), add Options -Indexes to the .htaccess file or server configuration. Ensure this setting is applied globally across all directories.

Finding Evidence

Index of /patient/

Name ↕	Last Modified ↕	Size ↕
⤴ Parent Directory		
📁 reports	2026-09-04 02:03	-
📄 download.php	2026-09-04 02:04	1k
📄 error_log	2026-09-05 16:23	241k
📄 login.php	2026-09-04 14:28	4k
📄 logout.php	2026-09-04 02:04	1k
📄 portal.php	2026-09-04 02:04	3k

Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443

Finding 6: Username Enumeration on Login Form			MEDIUM
CVSS Score	CWE	Component	Overall Risk
5.3	CWE-204	Patient Portal Login (/patient/login.php)	MEDIUM

Description

The patient portal login form returned different error messages depending on whether the supplied username existed in the database. When an invalid username was submitted, the application returned "Invalid username". When a valid username was submitted with an incorrect password, the application returned "Invalid password". This allows an attacker to determine which usernames are registered in the system.

Security Impact

Username enumeration reduces the effort required to conduct brute-force or credential stuffing attacks by allowing an attacker to first compile a list of valid usernames before attempting password attacks. Combined with the SQL Injection vulnerability (Finding 1), this finding is of reduced standalone severity — however it would become highly relevant once the SQL Injection is remediated.

Remediation

Configure the application to return identical, generic error messages for all authentication failures, regardless of whether the username or password is incorrect. The recommended message is: "Invalid username or password." Additionally, implement account lockout or CAPTCHA after a defined number of failed login attempts.

Finding Evidence

The application returned distinct error messages for invalid usernames versus valid usernames with incorrect passwords, enabling enumeration of registered accounts.

Finding 7: Verbose SQL Error Messages Exposed to End User			LOW
CVSS Score	CWE	Component	Overall Risk
3.1	CWE-209	Patient Portal Login (/patient/login.php)	LOW

Description

The web application was configured to display detailed PHP and MySQL error messages directly to end users. When a malformed SQL query was triggered, the application returned the full error: "Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version...". This confirmed the database technology in use (MySQL) and the specific query parameter causing the error.

Security Impact

Verbose error messages provide an attacker with valuable information about the application's internal architecture, database type, and query structure. This information directly assisted in crafting and confirming the SQL Injection payload used in Finding 1.

Remediation

Disable PHP error reporting in the production environment by setting `display_errors = Off` and `log_errors = On` in the `php.ini` configuration file. Errors should be logged server-side for debugging purposes but never displayed to end users.

Finding Evidence

Warning: mysqli_query(): You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near " OR '1'='1' at line 1

Figure: Verbose MySQL error — confirms database type and injection point

Appendices

Appendix A — Finding Severity Definitions

Rating	CVSS Score	Definition
CRITICAL	9.0 – 10.0	Exploitation will cause severe harm. Immediate resolution required. Direct risk to sensitive data, system integrity, or business operations.
HIGH	7.0 – 8.9	Exploitation will cause significant harm. Resolution required in the short term.
MEDIUM	4.0 – 6.9	Exploitation will have a meaningful impact. Should be resolved as part of ongoing security maintenance.
LOW	1.0 – 3.9	Exploitation causes minimal impact. Should be addressed as part of routine maintenance.
INFO	0.0 – 0.9	Informational finding. No direct vulnerability but represents an area for security improvement.

Appendix B — Vulnerabilities Summary

Finding	Vulnerability	CVSS	Severity
1	SQL Injection — Authentication Bypass	9.8	CRITICAL
2	Exposed Database Backup File	9.1	CRITICAL
3	Weak PDF Encryption Passwords	7.5	HIGH
4	Sensitive Path Disclosure via robots.txt	5.3	MEDIUM
5	Directory Listing Enabled	5.3	MEDIUM
6	Username Enumeration on Login Form	5.3	MEDIUM
7	Verbose SQL Error Messages	3.1	LOW

This report was prepared by Saad Kashif as part of the Networkwalks Internship Programme (Batch B082, Week 4). All testing was conducted under formal written authorisation from Mediroza General Hospital. The techniques documented herein must never be applied to any system without explicit written permission from the owner.

© 2026 Networkwalks. All rights reserved. CONFIDENTIAL.

